

Security review — 2026-07 resubmission

Point-in-time security assessment of the Claude apps gateway deployment (AWS GovCloud `us-gov-west-1`) for the ATO **resubmission** package.

This document is the successor snapshot to [security-review-2026-07.md](#) (the living finding-by-finding log and fix history, which remains the source of truth for the *status* of every earlier finding). Everything in the original review's batches A–E, C12, and the fix log is **implemented as of the commit reviewed here**; this assessment re-examines the whole posture as it stands now — including every surface added since the original review (spend caps + portal admin page, Bedrock prompt logging, Grafana 13, the telemetry loopback sidecar, the managed client policy, the offline mirror layer, the three-model Sonnet 5 rollout, and the portal's dependent dropdowns).

Assessment date	2026-07-27
Commit reviewed	<code>a3ba69f</code> (branch <code>main</code> ; automated passes at <code>712f25e</code> , later commits reviewed manually — see Methodology)
Reviewed by	Multi-agent review team (methodology below), operator: S. Buxton
Result	0 critical, 0 high, 5 medium, 20 low, 2 info confirmed findings; 4 documentation-drift items (fixed in this change); 4 raised-then-refuted claims (appendix B)

Read §1 first. Per this repo's standing process rule, accepted risks and deliberate trade-offs are stated up front, not buried.

Methodology

The review was performed by a structured multi-agent team, with models matched to task difficulty, over eight dimensions:

- Finders** — seven independent reviewers (Claude Sonnet), one per dimension: IAM & least privilege; network & transport; secrets & key management; authentication & authorization; application/script code security; audit, logging & retention; supply chain & offline build. Each read the actual templates/code and was required to cite file:line evidence for every claim, and to check the original review so accepted risks are not re-reported as new findings.
- Doc-accuracy sweep** — one mechanical cross-checker (Claude Haiku) grepping every checkable factual claim in the ATO package docs against the templates and scripts.
- Adversarial verifiers** — seven independent verifiers (Claude Fable, high effort), one per finder, instructed to *refute* each finding: re-read the cited code, web-check the AWS/PostgreSQL/ Grafana/OIDC semantics the claim hinges on against authoritative docs, check whether the item is already a documented accepted risk, and recalibrate severity to realistic exploitability in *this* architecture (internal ALB, ZPA-fronted clients, no-NAT spoke). Default verdict on ambiguity was REFUTED.

36 raw findings were produced; 28 survived verification (4 refuted — appendix B), and one confirmed finding was merged into another as a duplicate across dimensions, leaving **27 unique confirmed findings** plus the 4 doc-drift items. Severity below is the **calibrated** (post-verification) severity; where the verifier lowered a finder's severity, the finding notes it.

The automated passes ran against commit `712f25e`; the four commits that landed between then and the reviewed HEAD were reviewed manually. `d6d150c` (portal dependent dropdowns) *narrows* the portal's input validation (the (team, cost-center) pair is validated against a single mapping; malformed mappings fail the task at boot; all render paths HTML-escape; the page remains JavaScript-free) — no new finding; APP-4 below was re-verified against the new code and still applies. `a740800` is a gitignore change. `c5f0580` splits the portal image's staged extra trust anchors one-cert-per-file so `openssl rehash` installs them with hash symlinks — a build-time trust-store fix, runtime-verified in its own change, with no change to what is trusted. `a3ba69f` restructures `client-config.md` (documentation only).

Severity scale: **CRITICAL** (exploitable now, high impact) / **HIGH** (exploitable with realistic preconditions, high impact) / **MEDIUM** (real gap, moderate impact or notable preconditions) / **LOW** (hardening or defense-in-depth gap with strong compensating controls) / **INFO** (observation; no threat actor or no trust boundary crossed).

1. Accepted risks & deliberate trade-offs (state these in the SSP)

These are known, decided, and documented — none is a new finding. Full history and rationale for each is in the living review doc.

1. **S3 Object Lock is deferred (C9)**. Audit/log S3 archives (activity stream, Bedrock prompt logs, ALB access logs) are CMK-encrypted, IAM-scoped, versioned where applicable, and `Retain`-protected, but a principal with sufficient S3/IAM privilege could still delete or shorten retention. Deliberate deferral (user decision 2026-07-15); revisit if the AO requires WORM.
2. **The former plaintext gateway→collector OTLP hop (C2) no longer exists** — resolved by hop elimination, not TLS. The ADOT collector is a loopback sidecar inside the gateway task; telemetry never crosses the network (SC-8 by absence of transmission). The `CLAUDE_GATEWAY_ALLOW_LOOPBACK=1` override this requires is gated on telemetry being enabled, re-permits **only** loopback (IMDS/link-local stay blocked — probe-verified), and is pinned by a CI template test.
3. **Spend enforcement fails closed** (`enforcement.fail_closed_on_error: true`): a spend-store (RDS) outage halts **all** inference fleet-wide. This is a deliberate availability-for-control trade; the recovery runbook is `docs/operations/cost-controls.md` §5. See AUD-1 for the monitoring gap on this exact dependency.
4. **Bedrock model-invocation prompt logging (opt-in) is account- and region-wide**. When the org enables it, it captures verbatim prompts+responses of *every* bedrock-runtime call in the account+ region, not just this gateway's. Destinations (CMK CloudWatch group, 14d; CMK S3 bucket, 731d) are created unconditionally so that toggling the flag can never silently break delivery; the S3 grant is bucket-wide `PutObject` **bounded by** `aws:SourceAccount` + `aws:SourceArn` conditions (the AWS-prescribed pattern; the delivery prefix is service-managed and undocumented — tighten after first live delivery).
5. **ALB access-logs bucket is SSE-S3, not CMK** — ELB log delivery does not support KMS. The one deliberate exception to the everything-under-the-CMK rule.

6. `ClientIngressCidr` **must be tightened per deployment** (original finding B2, addressed as documented guidance + `deploy.env` prompts, default still `10.0.0.0/8`). Restated here because its blast radius has grown: the same ALB SG now also fronts `/grafana` and the portal's `/portal/admin` `spend-cap` page. All three paths independently require Okta OIDC with group checks, and the ALB is internal in a no-NAT spoke — but the CIDR is the pre-auth reachability bound and should be the App Connector source range, not a `/8`.
 7. **The `ecs` interface endpoint carries no endpoint policy** — GovCloud does not support one there; compensated by IAM-side scoping.
 8. **Client-side `Bash` `curl/wget` remains a web path** for end users (managed policy denies `WebFetch/WebSearch/mcp__*` but deliberately not `Bash` or subagents), bounded by client-side Zscaler (user decision 2026-07-24).
 9. **Session/token TTL is the deprovisioning latency bound** for the portal and the `spend-admin` surface (see AUTH-1): a user removed from an Okta group retains `portal/download` (up to `SessionTtlHours`, default 8 h) and `spend-admin` capability (bounded by the gateway token, default 1 h) until expiry. Compensating control: offboarded users also lose ZPA network access. State the configured TTLs in the SSP.
-

2. Posture strengths (verified, with evidence)

What the review confirmed is *right*, by control family. Each item was independently verified against the code at the commit under review.

Access control / least privilege (AC-3, AC-6) - Bedrock task-role and interface-endpoint policies enumerate exactly the three configured inference-profile IDs and their derived foundation-model ARNs — not `anthropic.*` (02-gateway.yaml:877-900, 1780-1799), including the new three-model set. - Execution-role vs task-role separation is consistent across all four stacks; every execution role's `GetSecretValue` list matches 1:1 the secrets its own task definition injects — no role can read a secret its task never uses. - The db-admin rotation Lambda is scoped to exactly its app secret, one ECS service ARN, and read-only on the master secret (02:1544-1576); the RDS master secret is genuinely break-glass — no task injects it. - The portal holds **zero** standing AWS privilege or gateway credential for `spend` administration: admins act as themselves via the gateway's OAuth device flow (RFC 8628), the gateway re-checks the token's groups claim per call, and `admin_audit` records `oidc:<sub>`, not a shared key id.

Network & transport (SC-7, SC-8) - Every SG in all four templates declares explicit egress (no implicit allow-all), enforced by a `cfn-guard` CI gate, not convention. - No plaintext hop exists anywhere: no HTTP:80 listener; the ALB re-encrypts to per-task TLS on all three targets, each with an explicit `HealthCheckProtocol: HTTPS` (also CI-gated); RDS is `sslmode=verify-full` against the OS trust store; telemetry is loopback-only inside one task network namespace. - The portal's gateway HTTP client disables redirect-following before attaching a bearer token — the token cannot be replayed to an arbitrary `Location: host`.

Identity & sessions (IA-2, IA-5, SC-23) - Portal OIDC is a full authorization-code flow with state + PKCE(S256) + nonce; ID-token verification hard-pins RS256 (no `alg:none`/HS256 confusion), filters JWKS keys on `key/use`, and uses constant-time comparisons; authorization is evaluated only after full token verification. - Admin mutations layer a synchronizer CSRF token on top of `SameSite=Lax`, with the correct rationale documented (Lax does not stop same-registrable-domain sibling apps). - Grafana OAuth is fail-closed: `ROLE_ATTRIBUTE_STRICT=true`, anonymous off, sign-up off, PKCE on, login form disabled by default. - Secret hygiene is uniform: `put_secret_and_roll` (mode-600 tempfile, never `argv`), `umask 077` before materializing secret-bearing config, `env vars` unset before exec, and read/write key separation for the `spend-admin` API.

Audit & monitoring (AU-2, AU-5, AU-9, AU-11) - The telemetry sidecar is genuinely fail-closed (Essential + health-checked; the gateway waits on HEALTHY and flushes before the collector drains on stop), and the missing-telemetry alarm handles AMP's absent-metric semantics correctly (`TreatMissingData:breaching`) with a real end-to-end heartbeat exercising the full SigV4+KMS+AMP write path. - pgaudit captures ddl/role/write with `log_parameter=0` (bind values — which may carry user content — stay out of the log), and the RDS-auto-created log group is pre-adopted under CMK + Retain. - Every log group in all four templates carries CMK + Retain + the retention tag that defeats CloudFormation no-op bug #1543. - Bedrock prompt-logging trust is confused-deputy-scoped (`aws:SourceAccount` + `aws:SourceArn`) consistently in all three places it must be: CMK grant, bucket policy, delivery-role trust.

Supply chain & offline build (SI-7, CM-8, CM-14) - Mirror consumption fails closed everywhere: `require_mirrored_file` + `verify_sha256` gate the Claude binary, RDS CA bundle, and Grafana plugin, each naming the exact mirror script to run on the egress host. - No Dockerfile fetches anything at build time — Python deps install `--no-index` from committed, exact-pinned vendored wheels; runtime requirements are `==`-pinned. - `mirror-base-images.sh` pulls with `--platform linux/amd64` + a post-pull arch assertion, pushes to CMK+IMMUTABLE per-base repos with content-derived tags, and fails closed without a CMK (`ALLOW_NONCMK_BASE_REPOS=1` is the named override). - ECR tag immutability is enforced and back-filled on pre-existing repos; release-manifest GPG verification fails closed (`ALLOW_UNVERIFIED_MANIFEST=1` is the named, deliberate override).

Input validation & money (SI-10) - The portal's dependent-dropdown change validates the (team, cost-center) *pair* against a single operator-supplied mapping, fails the task at boot on malformed config, and keeps every render path HTML-escaped with a script-free CSP. - Money handling is exact integer-cents string arithmetic with strict format validation — no float rounding class. - The rotation Lambda's one string-built SQL statement (ALTER ROLE cannot take a bind parameter) inlines only alphanumeric generated passwords (`ExcludePunctuation=True`) and double-quotes the one dynamic identifier — a narrow, reasoned exception, not a pattern.

3. Confirmed findings

No critical or high findings. Summary, most severe first:

ID	Sev	Controls	Area	Finding
AUD-1	MEDIUM	AU-5, SI-4	01-database.yaml	No alarm on the fail-closed spend-store dependency; 01 defines zero alarms
AUD-2	MEDIUM	SI-4, AU-5	telemetry	No automated detection for <code>failed_translations</code> — the already-realized silent metrics-loss mode
AUD-3	MEDIUM	AU-9, AU-11	03-observability.yaml	Firehose leg of the activity archive is unmonitored; the 731-day copy can silently stop
AUD-4	MEDIUM	AU-2, AU-5	portal	Portal audit writes fail open, swallowed with no alarm or metric filter
SUP-1	MEDIUM	CM-8, SI-7	mirror-collector.sh	No arch pin/assert + fixed immutable tag: a wrong-arch push blocks the fail-closed gateway and needs manual ECR cleanup
IAM-1	LOW	AC-6, SC-12	02/03/04	Six CMK <code>Decrypt / GenerateDataKey</code> grants lack <code>kms:ViaService</code> conditions (BYO-key blast radius)
IAM-2	LOW	AC-6, SC-7	02-gateway.yaml	Secrets Manager endpoint policy's <code>secret:rds!*</code> matches every RDS-managed secret in the account
IAM-3	LOW	AC-6	common.sh	ECR Lambda-pull repo policy scopes by account only, no <code>aws:SourceArn</code>
NET-1	LOW	SC-7, CM-8	tests/cfn	No CI gate on SG CIDR/source breadth (only presence-of-egress is checked)
KEY-1	LOW	SC-28, IA-5	portal	Admin gateway access+refresh tokens ride a signed-but-unencrypted persistent cookie
KEY-2	LOW	SC-28	build scripts	Gateway/Grafana TLS key generation omits the repo's own <code>rm -f -before-umask</code> rule (portal script has it)
AUTH-1	LOW	AC-2, AC-3	portal/gateway	Group membership is frozen into session/token for its TTL — deprovisioning latency (see §1.9)
AUTH-2	LOW	AC-6, IA-2	portal	No step-up/confirmation for org-wide spend-cap writes within a connected session
AUTH-3	LOW	AU-2	portal	Failed CSRF checks on admin endpoints are not audited (group denials are)
AUTH-4	LOW	AC-3, CM-6	03-observability.yaml	Grafana group params lack the <code>AllowedPattern</code> their gateway equivalent got, and splice into JMESPath
AUTH-5	LOW	IA-2	portal	The oversized-cookie guard built for <code>portal_gw</code> was not applied to <code>portal_session</code> (silent login loop)
APP-1	LOW	SI-11, AU-9	portal	OAuth <code>code + state</code> are logged verbatim on token-exchange failure (unhandled-error path logs full URL)
APP-2	LOW	CM-6, SC-23	portal	<code>SESSION_SECRET / OIDC_CLIENT_SECRET</code> default to <code>""</code> instead of failing closed at boot
APP-3	LOW	SC-23	portal	Authenticated pages (incl. admin + audit views) sent without <code>Cache-Control: no-store</code>
APP-5	LOW	SC-5	portal	No socket read timeout; slow clients can hold worker threads (slow-body/ALB-idle residual)
AUD-5	LOW	SI-4	02-gateway.yaml	No ALB/ECS availability alarms (unhealthy hosts, 5xx, running-task count)
SUP-2	LOW	CM-14, SI-7	build scripts	Mirrored base-image override is unenforced; builds silently fall back to floating upstream tags where egress exists
SUP-3	LOW	SI-7	CI	cfn-guard installer piped from a floating <code>main</code> branch into <code>sh</code> , unverified (cfn-lint also unpinned)
SUP-4	LOW	SI-7	CI	Test dependencies are open-ended <code>>=</code> with no lockfile or hashes

ID	Sev	Controls	Area	Finding
SUP-6	LOW	SI-7	mirror layer	Vendored wheels staged with plain <code>pip download</code> — no hash manifest, unlike every other mirrored artifact
APP-4	INFO	SI-10	portal	Operator-config team/cost-center values not screened for " before splicing into generated <code>install.cmd</code>
SUP-5	INFO	SI-7	CI	Pester installed unpinned (<code>-SkipPublisherCheck</code> is inert on Linux runners)

Medium findings — detail

AUD-1 — No alarm covers the fail-closed spend-store dependency (AU-5, SI-4, AU-12; `cloudformation/01-database.yaml`).

`enforcement.fail_closed_on_error: true` makes RDS the availability gate for all inference fleet-wide — and `01-database.yaml` defines zero CloudWatch alarms (no DatabaseConnections, FreeStorageSpace, CPUUtilization, or event-subscription alarm). `cost-controls.md` §5 states plainly that detection today is "user reports plus the DB-side alarms in `om-runbooks.md` §9" — but §9's only DB-adjacent alarm is the rotation-Lambda errors alarm, not RDS health. *Verified; severity calibrated HIGH→MEDIUM*: the failure mode is self-announcing (fleet-wide 429s with the operator's blocked message, so developers notice in minutes) — the gap is paging/MTTR, not silent loss, and the ops docs disclose it honestly. *Recommendation*: add RDS alarms (DatabaseConnections / CPUUtilization / FreeStorageSpace, or an RDS event subscription) to 01, wired to the same `AlarmSnsTopicArn` 02/03 use. Note 01 currently has no `AlarmSnsTopicArn` parameter — small template addition.

AUD-2 — No automated detection for translation-dropped client metrics (SI-4, AU-5; `sidecar/AMP`). The 2026-07-24 incident: client metrics silently dropped at prometheus translation while every counter looked healthy — the only live giveaway was

`otelcol_exporter_prometheusremotewrite_failed_translations` climbing, found by an operator. The root cause is fixed at the source (managed policy pushes cumulative temporality to every client), but no automated detection was added, and the missing-telemetry alarm is structurally blind to this mode: its heartbeat is the collector's own already-cumulative self-metrics, which keep flowing while 100 % of client metrics are dropped. *Verified; severity calibrated HIGH→MEDIUM*: root cause fixed; the review doc names the alarm's degradation-blindness as a known limit; `amp-query.py` verdicts on `failed_translations` first (manual, on-demand coverage). Note the finder's one-line fix is **not implementable as written** — the counter lives in AMP, which CloudWatch alarms cannot evaluate; closing this needs AMP rule groups + alertmanager→SNS (new infrastructure). *Recommendation*: either build the AMP-alerting path, or document the operator cadence for running `amp-query.py/checking failed_translations` as the compensating control in the SSP.

AUD-3 — The durable activity-archive leg is unmonitored (AU-9, AU-11, AU-5; `cloudformation/03-observability.yaml:488`). The activity chain is CloudWatch (14 d) → SubscriptionFilter → Firehose → S3 (731 d). The optional missing-activity-logs alarm watches CloudWatch ingestion only; nothing watches Firehose `DeliveryToS3.Success/DataFreshness` or objects under `errors/`. A broken Firehose role/filter leaves the alarm green while the copy that carries the 2-year retention silently stops — discoverable only when someone needs data older than 14 days. *Verified as filed (MEDIUM)*. *Recommendation*: alarm on `DeliveryToS3.Success` or `DataFreshness`, wired to `AlarmSnsTopicArn`.

AUD-4 — Portal audit writes fail open, silently (AU-2, AU-5, AU-9; `docker/portal/app.py:873-884`). `AuditLogger.write()` swallows all `put_log_events` exceptions with a `log.error()` into the *operational* log group — not the SIEM-flagged `portal-audit` group (which is precisely the write that failed) — and `_ensure_stream` swallows failures at debug level, so a permanent error (e.g. AccessDenied) silences every subsequent audit write for the task's life. Stack 04

defines no alarms or metric filters at all. *Verified (MEDIUM), with one moderating fact the finder missed:* admin spend-cap actions are independently recorded in the gateway's Postgres `admin_audit` table, so only download/denial events are single-trail. *Recommendation:* metric filter on the operational group for `audit write failed` (or an IncomingLogEvents dead-man alarm on the audit group), wired to `AlarmsTopicArn`.

SUP-1 — `mirror-collector.sh` lacks the arch pin/assert its sibling established, and pushes a fixed tag into an IMMUTABLE repo (CM-8, SI-7; `scripts/mirror/mirror-collector.sh:21-24`). `mirror-base-images.sh` documents and fixes the exact hazard: an unpinned `docker pull` on a non-x86_64 mirror host (e.g. Apple Silicon) silently mirrors the wrong architecture. `mirror-collector.sh` performs the same operation with no `--platform linux/amd64`, no post-pull assert, and a fixed `${ADOT_VERSION}` tag — so a wrong-arch push both **blocks the gateway from serving** (the collector sidecar is Essential + health-checked; exec-format failure keeps it unhealthy, and the gateway waits on HEALTHY by design) and **cannot be corrected by re-running** (ECR IMMUTABLE rejects the same-tag re-push; recovery is a manual `batch-delete-image` + re-mirror). *Verified; severity calibrated HIGH→MEDIUM:* fires only from a non-x86_64 mirror host; the impact is availability-only and surfaces loudly at deploy, not silently. *Recommendation:* back-port the `--platform` pin + arch assert; either adopt the content-derived tag scheme or document the recovery path.

Low / info findings — detail

IAM-1 — Unconditioned CMK grants on six roles (AC-6, SC-12; `02-gateway.yaml:857, :1566`; `03-observability.yaml:481, :786`; `04-download-portal.yaml:407, :433`). Six roles get `kms:Decrypt` (two also `kms:GenerateDataKey`) on the bare CMK ARN with no `kms:ViaService/encryption-context` condition — inconsistent with the same templates' AMP grants, which are `ViaService`-scoped. With the default stack-created CMK the exposure is minimal; with the **bring-your-own-key** parameter pointed at a shared enterprise CMK, these roles gain decrypt capability over that keyring's whole ciphertext universe. All six roles are service-assumed and their resource lists prevent easy ciphertext access — hence LOW (calibrated from MEDIUM). The db-admin Lambda instance of this pattern was independently verified safe to fix: nothing in its path needs KMS outside Secrets Manager. *Recommendation:* add `kms:ViaService` (`secretsmanager` / `s3` as appropriate) to all six grants.

IAM-2 — `secret:rds!*` in the Secrets Manager endpoint policy (AC-6, SC-7; `02-gateway.yaml:1913-1915`). The endpoint policy correctly scopes to `${NamePrefix}/*` but adds `secret:rds!*` for the RDS-managed master secret — a pattern that matches **every** managed-master-password RDS instance in the account/region, including write/re-stage actions. Defense-in-depth gap only (the sole principal that touches the master secret imports its exact ARN). *Recommendation:* import 01's `DBMasterSecretArn` output into the endpoint policy instead of the wildcard.

IAM-3 — ECR Lambda-pull policy lacks `aws:SourceArn` (AC-6; `scripts/common.sh ensure_ecr_repo`). The `lambda.amazonaws.com` pull grant is conditioned on `aws:SourceAccount` only; AWS's own examples add `aws:SourceArn` for the consuming function, and both db-admin call sites know their function names. *Recommendation:* optional function-ARN argument to `ensure_ecr_repo`.

NET-1 — No CI gate on SG rule breadth (SC-7, CM-8; `tests/cfn/rules.guard`). `cfn-guard` asserts that explicit egress *exists* and health checks are HTTPS, but nothing asserts rule *breadth* — a future edit widening a source SG to `0.0.0.0/0`, or a broader `ClientIngressCidr`, passes CI. *Recommendation:* add a guard rule/template test on ingress-egress CIDR breadth outside the reviewed egress rules.

KEY-1 — Admin tokens in a signed-but-unencrypted cookie (SC-28, IA-5; `docker/portal/app.py:648-661`). `portal_gw` carries the admin's live gateway access **and refresh** token HMAC-signed but plaintext-base64, persisted with `Max-Age`. Anyone reading the browser's cookie store lifts a replayable admin credential. Calibrated LOW: the cookie's expiry is `min(gateway token exp, session exp)` (gateway default 1 h); an attacker in that position already holds the portal session cookie with equivalent capability; `HttpOnly+Secure+SameSite` bound it. *Recommendation:* encrypt the payload (AES-GCM from the session secret) or drop the refresh token and re-connect per session.

KEY-2 — TLS key generation skips `rm -f` before umask-protected write (SC-28; `build-and-push-image.sh:65`, `build-and-push-grafana.sh:53`). Both scripts violate the repo's own rule (umask governs new files, not overwrites); the portal build script does it correctly. A pre-existing permissive `server.key` on a build host would stay permissive across regenerations. LOW: gitignored dir, per-build self-signed leaf for the ALB→task hop only. *Recommendation:* one-line `rm -f` inside the umask subshell, matching the portal script.

AUTH-1 — Authorization frozen for session/token lifetime (AC-2, AC-3; `docker/portal/app.py:1345`; gateway admin: **block).** Portal group checks are evaluated once at OIDC callback and cached in the signed session (default 8 h, max 24 h); the gateway re-checks the *token's* groups claim per call, not live Okta. Standard claims-in-token semantics — the ATO-relevant part is stating the TTL as the deprovisioning bound (§1.9). One caveat needing live confirmation: whether the gateway's refresh grant re-validates groups is gateway-binary-internal. *Recommendation:* document TTLs in the SSP; consider a userinfo re-check for the admin surface.

AUTH-2 — No step-up for org-wide cap writes (AC-6, IA-2; `docker/portal/app.py:1627`). One device-flow connect grants standing write capability (session + group + gw cookie + CSRF) for the token lifetime, with no confirmation tied to the org-wide scope — which interacts with fail-closed enforcement (a cap of \$0 org-wide halts the fleet). Calibrated LOW: the window is bounded by the gateway token (default 1 h), the gateway re-verifies groups per call, and the connect is itself fresh Okta-backed auth. *Recommendation:* confirmation step or fresh-cookie requirement for `organization`-scope writes.

AUTH-3 — CSRF failures unaudited (AU-2; `docker/portal/app.py:1586`, `:1619`, `:1632`). Group-membership denials are audited; failed CSRF checks on the three admin POST handlers return a bare 403 with no audit record — yet a forged-POST pattern is exactly the signal the audit trail should hold. *Recommendation:* audit write (`outcome=denied`, `reason=csrf`) on every `_csrf_ok` failure.

AUTH-4 — Grafana group params lack input hardening (AC-3, CM-6; `03-observability.yaml:140-156`). `SpendAdminGroups` got a strict `AllowedPattern` because it splices into generated config; the three Grafana group params splice unescaped into a JMESPath expression with no pattern at all. Failure mode is fail-closed (STRICT denies all logins on a broken expression) and the value is operator-supplied — LOW. *Recommendation:* apply the same `AllowedPattern`.

AUTH-5 — No size budget on `portal_session` (IA-2; `docker/portal/app.py:1345-1353`). `portal_gw` has an explicit ~3800-byte budget because browsers silently drop oversized Set-Cookie headers; `portal_session` embeds the same unbounded Okta groups list with no check — a user in many groups gets a silent login loop with no diagnostic. Fails closed; availability/ diagnosability only. *Recommendation:* apply the same budget or store only needed groups.

APP-1 — OAuth `code + state` logged on token-exchange failure (SI-11, AU-9; `docker/portal/app.py:1319`, `:1246`). `exchange_code` is unguarded; any Okta-side error (a user refreshing the callback URL suffices — 400 `invalid_grant`) propagates to the catch-all that logs `self.path` verbatim, including `?code=...&state=...`. Calibrated LOW: in the dominant trigger the code is already consumed; codes are one-time/~60 s; redemption needs the client secret +

PKCE verifier; destination is the CMK-encrypted, IAM-scoped log group. *Recommendation*: wrap the exchange; log only `urlparse(self.path).path` in the catch-alls.

APP-2 — Session/client secrets default to empty string (CM-6, SC-23; `docker/portal/app.py:70-71`). `SESSION_SECRET` (the HMAC key for **every** cookie incl. CSRF) and `OIDC_CLIENT_SECRET` use `env.get(..., "")` while sibling required config fails hard. The deployed task can't hit it (04 generates and injects the secret), but an out-of-band run boots with forgeable cookies instead of refusing — the repo's fail-closed rule applied everywhere else. *Recommendation*: switch both to the fail-hard `env[...]` form.

APP-3 — No `Cache-Control: no-store` on authenticated pages (SC-23; `docker/portal/app.py:1190-1196`). `_security_headers` sets `nosniff/frame/referrer/CSP` but no cache headers anywhere in the file — admin cap listings and the audit trail may persist in browser disk cache/history. Calibrated LOW on managed single-user ZPA laptops. *Recommendation*: add `no-store` in `_security_headers` (scope the download stream separately if resumption ever matters).

APP-5 — No read timeout on portal sockets (SC-5; `docker/portal/app.py:1709-1716`). `ThreadingHTTPServer` with no `timeout` — a slow client holds a thread indefinitely; pre-auth routes exist. Calibrated LOW: the ALB validates request headers before forwarding (classic Slowloris absorbed); the residual is slow POST bodies and idle-timer games by an inside-the-boundary attacker against the optional portal only. *Recommendation*: `PortalHandler.timeout = 30 + socket.timeout` handling.

AUD-5 — No ALB/ECS availability alarms (SI-4; `cloudformation/02-gateway.yaml`). Four alarms exist deployment-wide (cert expiry, rotation errors, missing telemetry, missing activity logs); none catches elevated 5xx or below-desired task count. Partially compensated: a full gateway outage indirectly fires the missing-telemetry alarm; DesiredCount 2 + health checks self-heal single-task failures. *Recommendation*: `UnHealthyHostCount / 5XX-rate / RunningTaskCount` alarms on `AlarmSnsTopicArn`.

SUP-2 — Base-image override unenforced (CM-14, SI-7; `build-and-push-*.sh`). The offline-build rule says the four `*_BASE_IMAGE` vars **must** be overridden in the target profile, but no build script checks: each defaults to a floating upstream tag. On the real air-gapped host this fails closed at `docker pull` (with an unhelpful error); on a partially-connected host the build silently uses an unverified, unpinned upstream tag — the one artifact class in the mirror layer with no integrity gate. Distinct from documented finding D11, which credits the override as mitigation without noting it is unenforced. *Recommendation*: refuse upstream defaults unless `ALLOW_UPSTREAM_BASE_IMAGE=1` (named override), matching the house pattern.

SUP-3 — CI's cfn-guard installer is a floating-branch curl|sh (SI-7; `.github/workflows/tests.yml:58-60`). The script fetched from `cloudformation-guard`'s `main` is unpinned and unverified (`-v 3.2.0` pins only the binary it goes on to fetch); the same job also `pip install cfn-lint` unpinned. Calibrated LOW: the runner holds no AWS credentials, CI is outside the ATO boundary, no deployed artifact flows from CI, and the local `make test cfn-guard` run backstops the gate signal. *Recommendation*: pin the installer to a commit SHA or verify its sha256; pin cfn-lint.

SUP-4 — Unpinned test dependencies (SI-7; `tests/requirements-test.txt`). All CI test deps are open-ended `>=` with no lockfile/hashes. Runtime images are unaffected (exact `=` pins, vendored wheels, `--no-index`); blast radius is test-signal corruption on a credential-less runner. *Recommendation*: `pip-compile --generate-hashes` lockfile.

SUP-6 — Vendored wheels lack a hash manifest (SI-7; `scripts/mirror/mirror-python-deps.sh:35`). Wheels are fetched with plain `pip download` at mirror time — the one externally-sourced artifact class without the sha256 discipline. The wheels are exact-pinned, committed, and installed `--no-index`, so the untrusted window is mirror-time only; a malicious wheel would appear in git only as a changed binary blob. *Recommendation:* `--require-hashes` lock for parity.

APP-4 (INFO) — Quote screening on generated-installer values (SI-10; `docker/portal/app.py _clean_token/build_install_cmd`). Operator-configured team/cost-center values are exact-match allowlisted and screened for whitespace/commas (and now `:|` by the dependent-dropdown parser) but not `"`, and are spliced quoted into the generated `install.cmd` PowerShell invocation. No trust boundary is crossed — the same operator already controls the served binary — so the realistic failure is self-inflicted installer breakage. *Recommendation:* extend `_clean_token` (and the installer's `validatePattern`) to reject `"` and backtick.

SUP-5 (INFO) — Pester install unpinned (SI-7; `.github/workflows/tests.yml:77`). `-SkipPublisherCheck` is inert on the Linux runner (publisher validation is Windows-only), leaving only an unpinned `-MinimumVersion` on a credential-less CI job. *Recommendation:* `-RequiredVersion` pin.

4. Documentation drift (found by this review; fixed in this change)

The mechanical doc-vs-code sweep verified retention day counts, secret names, log-group names, model IDs, parameter names, script paths, and listener priorities as **accurate** across the package. It found four gaps, all in `network-access-controls.md`, all the same root cause: the SG tables were not updated when stack 04 (download portal) landed. All four are fixed in the same commit as this document, along with a fifth drift item surfaced during verification (appendix B.3): the two spend-admin keys were missing from om-runbooks §7's secrets-inventory table (their rotation procedure was already documented in `cost-controls.md` §7 — the inventory now points at it):

1. The ALB row now lists `8080-portal (04)` egress and the conditional `443 from portal` ingress (the admin page makes the portal task an ALB *client*).
 2. The portal SG has its own inventory row (ingress 8080 from `alb`; egress 443 + optional proxy port).
 3. The cross-stack rule-writers list now includes 04's `AlbToPortalEgress`, `PortalToAlbIngress` (admin page enabled), and `PortalToEndpointsIngress` (shared endpoints enabled).
 4. The endpoint-SG row now includes `portal (04)` among its 443 sources.
-

5. Verification-status ledger

Per the repo's "done means verified live" rule, the following are **committed and code/offline-verified but not yet deploy-verified** at the reviewed commit; each has its live checklist in the living review doc / runbooks:

Surface	Verified so far	Needs live
Spend caps + admin keys + fail-closed enforcement	End-to-end against mirrored gateway + throwaway Postgres	02 re-run; real ALB/Okta flow
Portal <code>/portal/admin</code> (device flow)	Full offline round-trip incl. authz denials, audit actor	Real ALB/Okta; streamed download at size
Portal dependent dropdowns	Test suite (129 green); injection/bypass review	Portal image bump + 04 re-run
Managed policy (allowlist, denies, small-model pin)	Binary-verified against mirrored 2.1.211; policy-order runtime-verified	Deployed-image stanza check; <code>/model</code> in live session
Sonnet 5 three-model menu	Template/IAM enumeration; duplicate-ID guard	02 re-run; <code>/model</code> shows 3; background calls hit Sonnet 4.5
Bedrock prompt logging	Doc-verified; structural tests	GovCloud round-trip, SSE-KMS delivery, data prefix
Grafana 13.1.1	Runtime-verified <code>--network none</code> (boot, plugin, SigV4 path)	Okta login on 13.1; task-role creds from plugin subprocess
Loopback sidecar SSRF override	Probe-verified (IMDS still blocked)	Steady-state under load
<code>mirror-base-images.sh</code>	Stubbed docker/aws only	First target-profile run
Offline mirror→transfer→build chain	Fail paths exercised locally	Real two-host run

Deploy-verified and live-proven already: DB bootstrap + app-user auth + rotation path, RDS TLS verify-full, ALB + access logs, endpoint-SG reachability, AMP caller-side KMS grants, the telemetry heartbeat + missing-telemetry alarm, cumulative-temporality client metrics (`claude_code_*` flowing, `failed_translations` flat), and end-to-end gateway login.

6. Recommended remediation sequence

Ordered by risk-reduction per effort; none blocks resubmission (no critical/high), but the five mediums close real detection gaps around controls the package otherwise relies on:

- Alarm coverage batch (AUD-1, AUD-3, AUD-4, AUD-5)** — one 01/03/04 template pass adding RDS, Firehose-delivery, portal-audit, and ALB/ECS alarms to the existing `AlarmSnsTopicArn`. Small, mechanical, high assurance value.
- SUP-1** — back-port the arch pin/assert to `mirror-collector.sh` (availability of the fail-closed gateway path).
- AUD-2** — decide: AMP rule groups + alertmanager (build) vs documented operator cadence (SSP) for `failed_translations`.
- IAM batch (IAM-1, IAM-2, IAM-3)** — ViaService conditions, exact master-secret ARN in the endpoint policy, SourceArn on Lambda pull.
- Portal hardening batch (APP-1..3, APP-5, AUTH-3, AUTH-5, KEY-1)** — one `app.py` pass: guarded token exchange + path-only logging, fail-hard secrets, `no-store`, handler timeout, CSRF audit, session cookie budget, encrypted or refresh-free `portal_gw`.
- Supply-chain pinning batch (SUP-2..6, KEY-2, NET-1, AUTH-4)** — named-override base-image gate, pinned CI installers/deps, wheel hash lock, `rm -f` in TLS generation, SG-breadth guard rule, Grafana `AllowedPattern`.

Appendix A — dimension → confirmed-finding map

Dimension	Confirmed	Refuted	Strengths recorded
IAM & least privilege	IAM-1..3 (+1 merged into IAM-1)	1	6
Network & transport	NET-1	1	7
Secrets & keys	KEY-1, KEY-2	1	6
AuthN/AuthZ	AUTH-1..5	0	7
Application code	APP-1..5	0	7
Audit & monitoring	AUD-1..5	1	8
Supply chain	SUP-1..6	0	5
Doc accuracy	DOC (4, §4, fixed)	—	8

Appendix B — claims raised and refuted (transparency)

Recorded so the next reviewer doesn't re-litigate them:

1. **"S3 gateway-endpoint policy (`s3:*`, account-bounded) is overly broad."** Refuted: `aws:ResourceAccount` is the AWS-prescribed account-scoping pattern for S3 gateway endpoints; the sibling endpoint policies are account-granular on the resource axis too; and this is the documented C5 resolution. Residual (action-axis enumeration) is INFO-grade; the proposed fix is impossible as written (03/04 buckets don't exist when 02 deploys; the service-written buckets never transit the endpoint).
2. **"`ClientIngressCidr` default is too broad"** — real, but already finding B2 (addressed as documented guidance) and the /grafana co-tenancy note; restated as accepted-risk §1.6 with the grown blast radius rather than double-counted.
3. **"Spend-admin keys have no documented rotation"** — refuted: `cost-controls.md` §7 documents the full manual rotation procedure (file-based write + forced deployment), matching the repo's documented-manual-rotation posture (C11) for all non-DB secrets. Residual: the om-runbooks §7 inventory table omits the two keys — a two-row doc fix, tracked with the §4 items.
4. **"pgaudit/portal-audit lack an S3 durable copy (asymmetric with the activity stream)."** Refuted: the S3 leg exists only where the CloudWatch window is deliberately short; pgaudit's CloudWatch group itself carries the full 731 d (portal-audit 365 d) — retention parity in one durable store. The deletion-resistance angle is deferred finding C9 (accepted, §1.1). Residual: state the CloudWatch-only posture in the SSP.